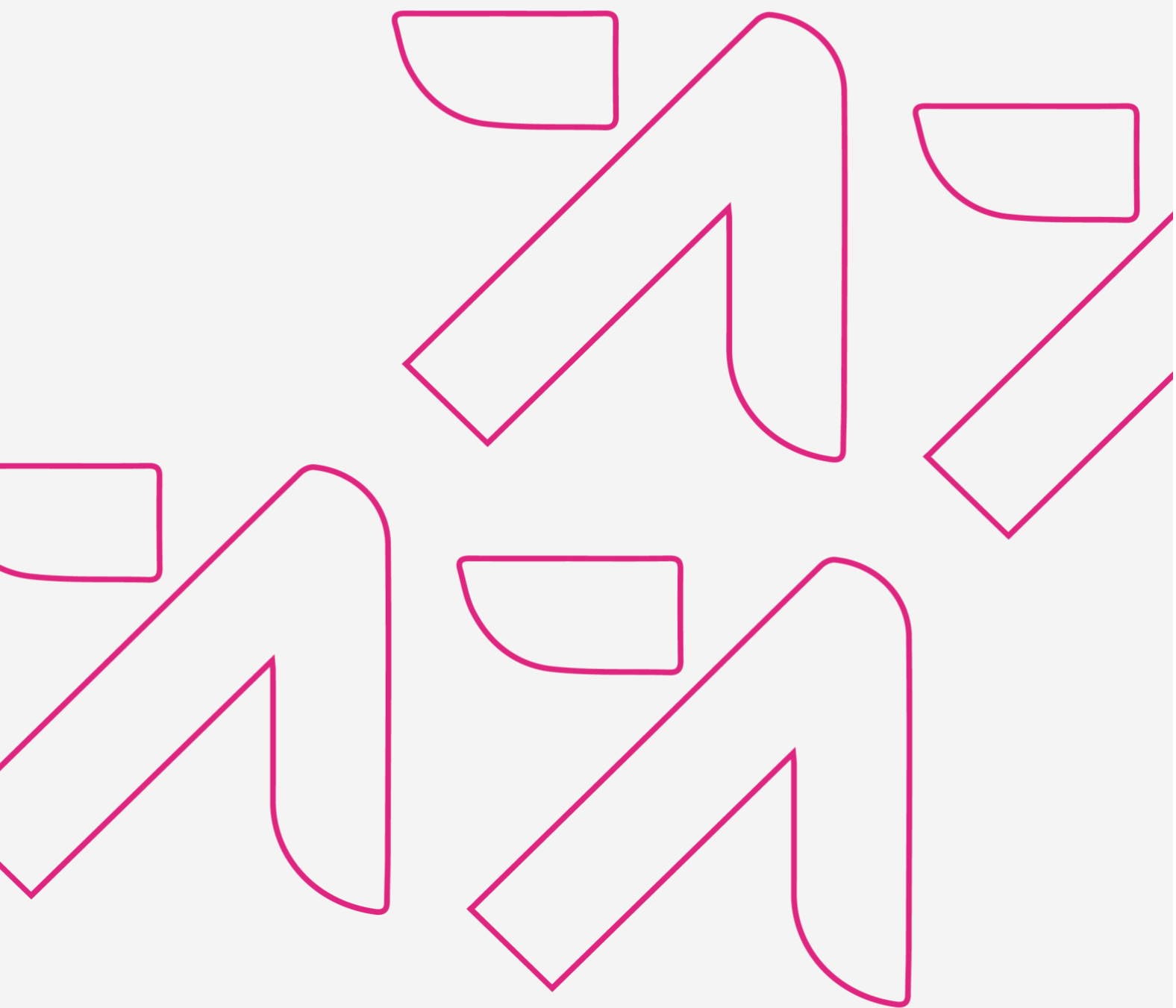




Máster de

Ciberseguridad Hacking Ético

[Módulo Incidentes de Ciberseguridad]

Curso académico 2026/2027 - Edición Presencial

Tema 5. Auditoría de incidentes de ciberseguridad

Encaje en el curso 2026/2027: tema 5 del temario oficial, dentro del RA3 (investigar incidentes analizando los riesgos y definiendo las medidas a adoptar).

1. Qué es una auditoría de ciberseguridad

Una auditoría es una revisión sistemática e independiente que comprueba, con evidencias, si la seguridad de una organización es la que debería ser. No busca culpables: busca diferencias entre lo que se dice que se hace, lo que se debería hacer y lo que se hace de verdad.

En este módulo interesa sobre todo desde dos ángulos: como forma de **anticiparse** a los incidentes y como forma de **revisar cómo se gestionó** uno que ya ha ocurrido.

1.1. Tipos

Criterio	Tipos
Quién la hace	Interna (personal propio independiente del área auditada) o externa (un tercero)
Qué revisa	De cumplimiento (frente a una norma: ENS, ISO 27001, RGPD) o técnica (análisis de vulnerabilidades, pruebas de intrusión, revisión de configuración)
Cuándo	Planificada o extraordinaria, tras un incidente grave

1.2. Auditoría, análisis de vulnerabilidades y pentest

No son lo mismo. El análisis de vulnerabilidades enumera fallos conocidos con herramientas automáticas; la prueba de intrusión intenta explotarlos para demostrar hasta dónde se llega; la auditoría es el marco más amplio, que incluye además procesos, personas y documentación.

2. Fases de una auditoría

2.1. Planificación inicial

- Objetivo y alcance: qué sistemas, sedes y procesos entran y cuáles no.
- Criterios: frente a qué se va a comparar (norma, política interna, buenas prácticas).
- Equipo, calendario y personas de contacto.
- Autorización por escrito de la dirección. Sin ella, una prueba técnica es un ataque.

2.2. Análisis de riesgos y amenazas

Inventario de activos (hardware, software, redes, datos, personas, proveedores), amenazas que les afectan, vulnerabilidades y controles existentes. El resultado orienta dónde mirar con más detalle: no se audita todo con la misma profundidad.

2.3. Trabajo de campo

- Revisión documental: políticas, procedimientos, registros de incidentes anteriores.
- Entrevistas con responsables y con usuarios.
- Pruebas técnicas: configuración, parches, permisos, copias de seguridad, registros.
- Observación directa: cómo se trabaja de verdad.

Cada hallazgo debe apoyarse en una evidencia que otra persona pueda comprobar.

2.4. Protocolos de actuación

La auditoría revisa si existen, y si se conocen y se siguen, los procedimientos para cuando algo falla: a quién se avisa, quién decide, cómo se contiene, cómo se recupera y cómo se comunica.

2.5. Informe

- Resumen ejecutivo, comprensible para la dirección.
- Alcance, criterios y metodología.
- Hallazgos, cada uno con evidencia, riesgo, severidad y recomendación.
- Plan de acción propuesto, con prioridades.

2.6. Monitorización y evaluación de resultados

La auditoría no termina con el informe. Las acciones correctivas tienen responsable y plazo, y se comprueba que se han aplicado y que funcionan. Un hallazgo que reaparece en la siguiente auditoría es, en sí mismo, un hallazgo más grave.

3. Hallazgos

3.1. Cómo se clasifican

Tipo	Significado
No conformidad mayor	Falta un control exigido o falla de forma generalizada
No conformidad menor	El control existe, pero falla de forma puntual
Observación	No incumple, pero puede acabar haciéndolo
Oportunidad de mejora	Recomendación sin incumplimiento

En auditorías técnicas se usa además la severidad (crítica, alta, media, baja), normalmente a partir del riesgo que supone.

3.2. Cómo se redacta un buen hallazgo

Cuatro elementos: **criterio** (qué debería ocurrir), **condición** (qué ocurre), **evidencia** (cómo lo sé) y **recomendación** (qué hacer). Por ejemplo: «La política exige MFA en todo acceso remoto. De las 40 cuentas con VPN, 6 no lo tienen activado (listado exportado el día de la

revisión). Se recomienda activarlo en 15 días y bloquear el acceso sin MFA por configuración».

4. Las tres líneas de defensa

El modelo reparte las responsabilidades de control dentro de la organización:

1. **Primera línea:** quienes operan los sistemas y aplican los controles en el día a día.
2. **Segunda línea:** las funciones que definen y supervisan (seguridad de la información, riesgos, cumplimiento).
3. **Tercera línea:** la auditoría interna, independiente de las otras dos, que informa a la dirección.

Los auditores externos y los reguladores quedan fuera del modelo, como garantía adicional.

5. Buenas prácticas en auditorías internas

5.1. Qué revisar siempre

- Inventario de activos y de cuentas, sobre todo privilegiadas.
- Gestión de parches y de vulnerabilidades.
- Copias de seguridad y, sobre todo, pruebas de restauración.
- Registros: qué se recoge, cuánto tiempo y quién los revisa.
- Accesos remotos y de proveedores.
- Formación y concienciación.
- Plan de respuesta a incidentes y de continuidad.

5.2. Cómo hacerlo bien

- Independencia: nadie audita su propio trabajo.
- Evidencias, no opiniones.
- Hallazgos sobre procesos, no sobre personas.
- Lenguaje claro y recomendaciones realistas para el tamaño de la organización.

6. Auditar la capacidad de respuesta a incidentes

Es la parte más propia de este módulo. Preguntas que debe poder contestar la organización:

Área	Pregunta
Plan	¿Existe un plan de respuesta aprobado, actualizado y conocido?
Roles	¿Está claro quién decide, también fuera de horario?

Detección	¿Qué fuentes se vigilan y quién atiende las alertas?
Registro	¿Se documenta cada incidente de principio a fin?
Evidencias	¿Se sabe cómo preservarlas?
Contactos	¿Están a mano los de proveedores, CSIRT, aseguradora y asesoría legal?
Copias	¿Se ha probado una restauración en el último año?
Simulacros	¿Se ha ensayado el plan alguna vez?
Mejora	¿Se revisan los incidentes cerrados y se aplican las lecciones?

7. Auditoría posterior a un incidente

Tras un incidente grave conviene una revisión específica: qué controles fallaron o faltaban, si se siguió el procedimiento, cuánto se tardó en detectar y en contener, y qué habría reducido el daño. Sus conclusiones alimentan las lecciones aprendidas del tema 9.

8. Marcos de referencia

- **ISO/IEC 27001:** requisitos de un sistema de gestión de seguridad de la información; exige auditorías internas periódicas.
- **ENS:** auditoría obligatoria al menos cada dos años para sistemas de categoría media y alta.
- **ISO 19011:** directrices para auditar sistemas de gestión.
- **ISO/IEC 27035:** gestión de incidentes de seguridad de la información.

Para ampliar

- ISO 19011 e ISO/IEC 27001 (cláusula de auditoría interna).
- Guía CCN-STIC 802: auditoría del ENS.
- INCIBE: guías de auditoría y de gestión de riesgos para empresas.
- Instituto de Auditores Internos: modelo de las tres líneas.